

Dan Boneh 密码学第一季：第六课 抗碰撞

本笔记按照课程讲义的主线整理：抗碰撞定义 → 生日攻击 → Merkle–Damgård 构造 → 压缩函数 → HMAC → MAC 验证的时序攻击。

1. 本课要解决什么问题

前几课讨论了加密与消息认证。本课引入密码学哈希函数，并重点研究它的一项核心安全性质：**抗碰撞性**。

学完本课，应当能够回答：

1. 什么是哈希碰撞，为什么碰撞必然存在但仍可要求“难以找到”？
2. 为什么 n 位哈希的通用碰撞攻击复杂度只有约 $2^{n/2}$ ，而不是 2^n ？
3. 如何用固定输入长度的压缩函数构造可处理任意长消息的哈希函数？
4. 为什么 Merkle–Damgård 构造需要把消息长度写进填充？
5. Davies–Meyer 如何把分组密码变成压缩函数？
6. 为什么 $H(k \parallel m)$ 不能直接作为基于 Merkle–Damgård 哈希的 MAC？
7. HMAC 为什么采用内外两层哈希？
8. 即使 MAC 本身安全，验证代码为什么仍可能泄露标签？

2. 哈希函数与抗碰撞性

2.1 基本形式

密码学哈希函数把很大的消息空间映射到较小且固定长度的输出空间：

$$H : \mathcal{M} \rightarrow \mathcal{T}, \quad |\mathcal{M}| \gg |\mathcal{T}|.$$

- $m \in \mathcal{M}$ ：任意长度或较长的输入消息；
- $H(m) \in \mathcal{T}$ ：固定长度的哈希值，也称摘要；
- 若输出为 n 位，则 $|\mathcal{T}| = 2^n$ 。

哈希函数通常是公开、确定且高效的，不依赖秘密密钥。

2.2 什么是碰撞

若两条不同消息具有相同摘要：

$$m_0 \neq m_1, \quad H(m_0) = H(m_1),$$

则称 (m_0, m_1) 是 H 的一个碰撞。

由于输入空间远大于输出空间，根据抽屉原理，碰撞一定存在。抗碰撞性并不是说“没有碰撞”，而是说：**计算能力受限的攻击者难以找到任何一对碰撞**。

攻击者 A 的抗碰撞优势可写成：

$$\text{Adv}_{CR}[A, H] = \Pr[A \text{ 输出 } m_0 \neq m_1 \text{ 且 } H(m_0) = H(m_1)].$$

如果所有现实可行的高效攻击者，其成功概率都可忽略，则称 H 是抗碰撞的。

2.3 三种常见安全性质

性质	攻击者得到什么	攻击目标	n 位理想哈希的通用复杂度
原像抗性	一个摘要 y	找 m, 使 $H(m)=y$	约 2^n
第二原像抗性	指定消息 m_0	找 $m_1 \neq m_0$, 使 $H(m_1)=H(m_0)$	约 2^n
抗碰撞性	无指定消息	自己找任意 $m_0 \neq m_1$, 使摘要相同	约 $2^{n/2}$

三者的量词和攻击者自由度不同，不能混为一谈。寻找碰撞时，攻击者可同时选择两条消息，因此可利用生日攻击。

3. 抗碰撞哈希的应用

3.1 把短消息 MAC 扩展到长消息

假设 $S(k, x)$ 是只支持短输入 x 的安全 MAC，而 H 能把长消息压缩成短摘要，可定义：

$$S_{\text{big}}(k, m) = S(k, H(m)).$$

它的安全性依赖两部分：

- S 本身必须是安全的 MAC；
- H 必须抗碰撞。

若攻击者找到 $m_0 \neq m_1$ 且 $H(m_0)=H(m_1)$ ，就可以：

1. 请求 m_0 的标签 $t=S(k, H(m_0))$ ；
2. 把同一标签 t 附到从未查询过的 m_1 上；
3. 因为两个摘要相同， m_1 也会通过验证。

因此，在这种构造中，哈希碰撞会直接变成 MAC 伪造。

3.2 大文件完整性验证

若从不可信网络下载大文件，可先通过可信渠道得到正确摘要 h ，再验证：

$$H(\text{downloaded file}) \stackrel{?}{=} h.$$

安全性的关键不是摘要是否保密，而是摘要是否来自可信位置。若攻击者能同时替换文件和公布的摘要，哈希函数本身无法提供真实性。

典型用途包括软件镜像校验、版本对象标识和数字签名前的消息压缩。

4. 通用生日攻击

4.1 为什么不是 2^n

设哈希输出空间大小为 $B=2^n$ 。随机选取 q 条不同消息并计算摘要，任意一对摘要发生碰撞的概率约为 $1/B$ ，而消息对数量约为 $q(q-1)/2$ 。

无碰撞概率近似为：

$$\Pr[\text{无碰撞}] \approx \exp\left(-\frac{q(q-1)}{2B}\right).$$

因此碰撞概率约为：

$$\Pr[\text{发生碰撞}] \approx 1 - \exp\left(-\frac{q(q-1)}{2B}\right).$$

令碰撞概率约为 1/2，可得：

$$q \approx \sqrt{2B \ln 2} \approx 1.2\sqrt{B}.$$

当 $B=2^n$ 时：

$$q = O(2^{n/2}).$$

直觉上，攻击者不是拿一个固定摘要逐个试，而是在约 $q^2/2$ 对样本之间同时寻找相等项。

4.2 实际攻击步骤

1. 生成约 $2^{(n/2)}$ 条不同消息；
2. 计算并保存所有摘要；
3. 按摘要排序或放入哈希表；
4. 找到摘要相同而消息不同的一对。

朴素实现的时间和空间都约为 $2^{(n/2)}$ 。存在降低存储的变体，但不会改变这里关注的通用安全量级。

4.3 输出长度意味着什么

- 128 位哈希的碰撞安全性最多约 64 位，已不足以应对强攻击者；
- 256 位理想哈希的碰撞安全性约 128 位；
- “256 位输出”不等于“256 位抗碰撞安全性”。

课程还指出，量子环境中通用碰撞搜索可达到：

$$O(|\mathcal{T}|^{1/3}) = O(2^{n/3}).$$

这是渐近结论；实际安全评估还要考虑量子计算资源和算法常数。

5. Merkle–Damgård 构造

5.1 从压缩函数到长消息哈希

先有一个固定长度输入的压缩函数：

$$h : \mathcal{T} \times \mathcal{X} \rightarrow \mathcal{T}.$$

其中：

- $H_i \in \mathcal{T}$ 是链值；
- $m[i] \in \mathcal{X}$ 是一个消息分组；

- 输出 H_{i+1} 仍是固定长度链值。

对填充后的消息分组 $m[0], \dots, m[L-1]$, 迭代计算:

$$\begin{aligned} H_0 &= IV, \\ H_{i+1} &= h(H_i, m[i]), \\ H(m) &= H_L. \end{aligned}$$

IV 是公开且固定的初始值, 不是密钥。

5.2 长度强化填充

典型填充方法是在原消息后加入:

1. 一个 1 比特;
2. 足够数量的 0;
3. 固定长度编码的原消息比特长度, 例如 64 位长度字段。

填充结果必须恰好是完整分组。即使当前空间不足以容纳长度字段, 也要再增加一个分组。

长度字段很重要, 因为它让不同原消息的完整填充分组序列保持可区分, 也让证明能够从最终状态向前追踪。

5.3 抗碰撞性定理

Merkle-Damgård 的核心定理是:

$$h \text{ 抗碰撞} \implies H \text{ 抗碰撞}.$$

也就是说, 若有人能有效找到迭代哈希 H 的碰撞, 就能由此构造出压缩函数 h 的碰撞。

5.4 证明思路: 从后往前找

设两条不同消息经过长度强化填充后得到分组序列:

$$x_1, \dots, x_s \quad \text{和} \quad y_1, \dots, y_t,$$

且最终哈希值相同。考虑最后一次压缩:

$$h(H_{s-1}, x_s) = h(H'_{t-1}, y_t).$$

分两种情况:

1. 若输入对 (H_{s-1}, x_s) 与 (H'_{t-1}, y_t) 不同, 那么这已经是 h 的碰撞。
2. 若输入对完全相同, 则有 $H_{s-1} = H'_{t-1}$ 且 $x_s = y_t$, 可以向前考察上一轮。

不断后退后, 必然出现某一轮的两个输入不同但输出相同, 否则两条完整的填充分组序列会完全相同。长度强化填充保证“完整填充序列相同”只能来自同一条原消息, 这与 $m_0 \neq m_1$ 矛盾。

所以, H 的任何碰撞都能导出 h 的碰撞。

5.5 定理没有保证什么

该定理只传递抗碰撞性, 并不自动保证:

- 原像抗性；
- 伪随机函数性质；
- 用 $H(k \parallel m)$ 构造 MAC 的安全性；
- 对长度扩展攻击的抵抗力。

“抗碰撞”只是哈希函数众多安全性质中的一项。

6. 用分组密码构造压缩函数

6.1 Davies–Meyer 构造

设 $E(k,x)$ 是分组密码，把消息分组 m 当作密钥，把链值 H 当作明文：

$$h(H, m) = E(m, H) \oplus H.$$

异或反馈是构造的关键部分。在理想分组密码模型下，若输出为 n 位，寻找碰撞的通用代价约为：

$$O(2^{n/2}).$$

6.2 为什么直接使用 $E(m,H)$ 不安全

若定义：

$$h(H, m) = E(m, H),$$

攻击者可以任取 (H,m) 和另一个密钥 m' ，再令：

$$H' = D(m', E(m, H)).$$

于是：

$$E(m', H') = E(m, H),$$

从而立即得到压缩函数碰撞。问题在于分组密码对每个密钥都是可逆置换，攻击者能够反向构造第二个输入。

6.3 Miyaguchi–Preneel 构造

另一种构造为：

$$h(H, m) = E(m, H) \oplus H \oplus m.$$

它同时反馈链值和消息分组，Whirlpool 哈希使用了这一类设计。

6.4 一个可证明但较慢的构造

讲义给出基于离散对数困难性的例子：

$$h(H, m) = u^H v^m \pmod{p}.$$

若能找到碰撞：

$$u^H v^m = u^{H'} v^{m'} \pmod{p},$$

则可从指数关系中导出关于 u 与 v 的离散对数信息。因此，找碰撞可归约到离散对数问题。不过模幂运算远慢于现代专用哈希结构，所以它主要用于说明“可证明安全”的构造思想。

7. SHA-256 结构实例

课程从高层把 SHA-256 看作：

- 使用 Merkle–Damgård 迭代；
- 消息分组为 512 位；
- 链值与最终摘要为 256 位；
- 压缩函数具有 Davies–Meyer 风格；
- 内部使用与 SHACAL-2 相关的分组密码式结构。

学习时应区分：

- SHA-256：完整哈希函数，可处理长消息；
- SHA-256 压缩函数：每次处理一个 512 位消息分组与一个 256 位链值；
- 轮函数：压缩函数内部更细粒度的一轮运算。

安全性不能仅由“轮数很多”得出，而要结合攻击结果、结构分析与输出长度评估。

8. 长度扩展攻击

8.1 不安全的前缀 MAC

一个自然但危险的方案是：

$$S(k, m) = H(k \parallel m).$$

若 H 是普通 Merkle–Damgård 哈希，公开的 $H(k \parallel m)$ 正好是处理完 $k \parallel m$ 及其填充后的链值。攻击者可把它当作新的内部状态，继续处理额外分组 w ，从而计算：

$$H(k \parallel m \parallel PB \parallel w),$$

其中 PB 是根据 $k \parallel m$ 的总长度推算出的填充。

攻击者虽然不知道 k 的内容，但如果能猜到或知道密钥长度，就可能构造有效的新消息与新标签。这就是长度扩展攻击。

8.2 它与碰撞攻击不同

长度扩展不需要找到 $m_0 \neq m_1$ 且哈希相等。它利用的是 Merkle–Damgård 输出暴露最终链值这一结构性质。因此，“哈希函数抗碰撞”并不能证明 $H(k \parallel m)$ 是安全 MAC。

9. HMAC

9.1 标准结构

HMAC 定义为：

$$\text{HMAC}(k, m) = H((k \oplus \text{opad}) \parallel H((k \oplus \text{ipad}) \parallel m)).$$

其中 ipad 和 opad 是两个固定且不同的填充值。实际规范还会先把密钥规范化到哈希分组长度。

计算分两层：

1. 内层：计算 $H((k \oplus \text{ipad}) \parallel m)$ ；
2. 外层：把内层摘要放入 $H((k \oplus \text{opad}) \parallel \cdot)$ 再哈希一次。

9.2 为什么外层能阻断长度扩展伪造

攻击者看到的是外层哈希的最终输出，而不是可直接接在原消息 m 后继续计算的内层链值。即使底层哈希具有长度扩展性质，也不能据此得到新消息对应的完整 HMAC。

HMAC 与 NMAC 思路相近，只是通过 $k \oplus \text{ipad}$ 与 $k \oplus \text{opad}$ 从一个密钥派生内外两层输入。其安全性不能只用抗碰撞性一句话概括；课程将其视为在适当假设下的安全 PRF 构造。

安全界通常会出现生日项：

$$\frac{q^2}{|\mathcal{T}|},$$

因此查询数量 q 应远小于 $|\mathcal{T}|^{1/2}$ 。

9.3 历史背景

讲义提到 TLS 曾要求支持 HMAC-SHA1-96，即对 HMAC-SHA1 输出截断后使用。这是课程所处协议版本的历史背景，不应理解为今天新系统的首选算法。现代系统通常选择标准库提供的 HMAC-SHA-256 或更现代的认证方案。

10. MAC 验证中的时序攻击

10.1 漏洞如何产生

假设服务器从左到右比较正确标签与用户提交标签，并在发现第一个不同字节时立即返回。匹配前缀越长，执行时间就可能越长。

攻击者可以逐字节恢复标签：

1. 枚举第一个字节的 256 种可能；
2. 多次测量每个候选值的响应时间并取统计结果；
3. 最慢的候选通常意味着第一个字节正确；
4. 固定该字节，再枚举下一字节；
5. 重复直到恢复整个标签。

网络噪声会增加测量次数，但不会自动消除泄露。

10.2 常数时间比较

常见思路是比较所有字节并累计差异，在结束前不因某一字节不同而提前返回：

```

result = 0
for x, y in zip(expected, supplied):
    result |= x XOR y
return result == 0

```

还应先以不泄露内容的方式处理长度差异。实际开发中不要自行编写这种底层代码，应使用语言或密码库提供并审计过的常数时间比较函数，因为编译器、解释器和运行时优化都可能破坏手写代码的时间特征。

10.3 讲义中的另一种思路

可先对待比较值再做一次带密钥计算，然后比较：

$$\text{HMAC}(k, \text{expected}) \stackrel{?}{=} \text{HMAC}(k, \text{supplied}).$$

其目的在于避免比较过程直接泄露原标签的逐字节信息。不过工程实践仍应优先使用成熟库的认证验证接口或常数时间比较接口。

核心教训是：**密码算法在数学上安全，不代表包含它的软件实现一定安全。**

11. 核心概念对照

概念	输入和输出	主要目标	是否带密钥	典型风险
哈希函数 H	任意长消息 → 固定长摘要	完整性指纹等	否	碰撞、长度扩展等
压缩函数 h	链值和单个分组 → 新链值	构造长消息哈希	否	结构性碰撞
Merkle–Damgård	重复调用 h	扩展输入长度	否	输出可作为续算状态
MAC	密钥和消息 → 标签	完整性与来源认证	是	伪造、重放、侧信道
HMAC	两层带密钥哈希	构造安全 MAC/PRF	是	错误比较、密钥管理

12. 常见误区

误区 1：抗碰撞意味着两条消息绝不会有相同哈希

错误。有限输出空间必然存在碰撞；安全性要求的是找碰撞在计算上不可行。

误区 2：n 位哈希提供 n 位碰撞安全性

错误。生日攻击把通用碰撞复杂度降到约 $2^{(n/2)}$ 。

误区 3：抗碰撞、原像抗性、第二原像抗性是一回事

错误。三种游戏中攻击者获得的信息和目标不同，通用攻击复杂度也不同。

误区 4：安全的分组密码直接拿来就是安全压缩函数

错误。 $h(H, m) = E(m, H)$ 可利用解密运算直接制造碰撞，需要 Davies–Meyer 等经过分析的结构。

误区 5：哈希函数抗碰撞，所以 $H(k \parallel m)$ 一定是安全 MAC

错误。Merkle–Damgård 哈希通常允许长度扩展；MAC 安全性也不只依赖抗碰撞性。

误区 6：标签内容正确，验证实现就安全

错误。提前返回的字符串比较可能通过运行时间泄露正确前缀。

误区 7：哈希摘要公开就失去作用

错误。摘要通常不需要保密，但必须保证其来源可信且未被替换。

13. 必记公式

碰撞定义：

$$m_0 \neq m_1, \quad H(m_0) = H(m_1).$$

生日攻击复杂度：

$$O(2^{n/2}).$$

Merkle–Damgård 迭代：

$$H_0 = IV, \quad H_{i+1} = h(H_i, m[i]).$$

Davies–Meyer：

$$h(H, m) = E(m, H) \oplus H.$$

HMAC：

$$\text{HMAC}(k, m) = H((k \oplus \text{opad}) \parallel H((k \oplus \text{ipad}) \parallel m)).$$

HMAC 安全分析中的生日项：

$$q^2/|\mathcal{T}|.$$

14. 自测题

题目

1. 既然碰撞必然存在，为什么还能说一个哈希函数抗碰撞？
2. 对 256 位理想哈希，通用碰撞攻击和原像攻击各需要多少量级的工作？
3. 生日攻击为什么只需约 $2^{n/2}$ 个样本？
4. Merkle–Damgård 中 IV 是秘密密钥吗？
5. 长度强化填充在抗碰撞证明中起什么作用？
6. 为什么 $h(H, m) = E(m, H)$ 容易被找到碰撞？
7. 长度扩展攻击是否等价于找到哈希碰撞？
8. 为什么 $H(k \parallel m)$ 不适合作为普通 Merkle–Damgård 哈希上的 MAC？
9. HMAC 的内外两层各起什么作用？

10. 为什么逐字节提前返回的标签比较不安全？

参考答案

1. 碰撞在信息论上存在，但抗碰撞要求任何现实可行的高效攻击者都难以找到它。
2. 通用碰撞攻击约 2^{128} ，原像攻击约 2^{256} 。
3. q 个摘要形成约 $q^2/2$ 对；当 q^2 与 2^n 同量级时，出现碰撞的概率已是常数量级。
4. 不是。IV 是固定、公开的初始链值。
5. 它把原消息长度编码进填充，使不同消息不会对应相同的完整填充分组序列，从而能从 H 的碰撞归约出 h 的碰撞。
6. 攻击者可选择第二个密钥 m' ，再通过解密构造 $H'=D(m',E(m,H))$ ，使两个输出相等。
7. 不是。长度扩展利用迭代哈希暴露最终链值，不要求两条不同消息具有相同摘要。
8. 已知标签可作为继续迭代的内部状态，攻击者可能在不知道密钥的情况下为扩展消息计算有效标签。
9. 内层把密钥与消息结合；外层封装内层摘要，避免把可直接续算的内层状态暴露给攻击者，并形成可证明分析的结构。
10. 执行时间会泄露已匹配前缀长度，攻击者可通过重复测量逐字节恢复标签。

15. 一页复习提纲

1. 哈希把大空间压缩到固定小空间，碰撞必然存在，安全目标是让碰撞难找。
2. n 位理想哈希的通用碰撞安全性约为 $n/2$ 位，因为生日攻击只需约 $2^{(n/2)}$ 次计算。
3. 抗碰撞、原像抗性、第二原像抗性的攻击游戏不同。
4. Merkle–Damgård 用固定长度压缩函数迭代处理任意长消息。
5. 长度强化填充把原消息长度写入末尾，是抗碰撞归约的重要条件。
6. 若压缩函数抗碰撞，则长度强化后的 Merkle–Damgård 哈希抗碰撞。
7. Davies–Meyer 使用 $h(H,m)=E(m,H)\oplus H$ ；不能简单使用 $E(m,H)$ 。
8. SHA-256 可从高层理解为 512 位消息分组、256 位链值的迭代哈希。
9. $H(k || m)$ 会受长度扩展攻击，抗碰撞性不能单独证明它是安全 MAC。
10. HMAC 使用内外两层哈希，是标准的带密钥消息认证结构。
11. MAC 标签必须用常数时间方式验证；软件侧信道可能破坏数学上的安全性。

16. 学习主线

可以把本课压缩成一条因果链：

长消息需要固定长度摘要 → 摘要必须抗碰撞 → n 位输出只能提供约 $n/2$ 位通用碰撞安全性 → 用抗碰撞压缩函数经 Merkle–Damgård 处理长消息 → 分组密码需通过 Davies–Meyer 等结构才能成为压缩函数 → Merkle–Damgård 又带来长度扩展问题 → 带密钥认证应使用 HMAC → 实现时还必须防范时序侧信道。

这条主线同时连接了本课的三个层次：安全定义、密码构造与工程实现。